المدرسة الوطنية العليا للذكاء الاصطناعي وعلوم المعطيات - تارودانت
ⵜⵉⵏⵎⵍ ⵜⴰⵏⴰⵎⵓⵔⵜ ⵜⴰⵏⴰⵅⵍⵍⴰⵜ ⵏ ⵡⴰⵏⵍⵍⵉ ⴰⵙⵎⴳⵓⵔ ⴷ ⵜⵎⴰⵙⵙⴰⵏⵉⵏ ⵏ ⵜⵎⵓⵛⴰ - ⵜⴰⵔⵓⴷⴰⵏⵜ
ÉCOLE NATIONALE SUPÉRIEURE DE L'INTELLIGENCE ARTIFICIELLE ET SCIENCES DES DONNÉES – TAROUDANT

Filière : Sécurité IT et Confiance Numérique - S5
Module : M352 — Sécurité de la virtualisation et du Cloud Computing
TD1 — Analyse des risques d'un environnement virtualisé

Objectif du TD
Appliquer une démarche structurée d'analyse des risques à un environnement virtualisé : identifier les actifs, menaces et vulnérabilités, évaluer vraisemblance et impact, prioriser les risques et proposer des mesures de traitement adaptées.

I. Cas d'étude : AtlasTech

AtlasTech est une PME de services numériques. Elle a consolidé plusieurs serveurs physiques sur un hôte de virtualisation HYP-01. L'environnement héberge quatre machines virtuelles critiques. L'équipe IT compte trois administrateurs.

Composant	Fonction	Zone / accès	Criticité métier
HYP-01	Hyperviseur et exécution des VM	VLAN administration	Très élevée
WEB-01	Portail Web public	DMZ — accessible depuis Internet	Élevée
APP-01	Application métier	Réseau serveurs	Très élevée
DB-01	Base de données clients	Réseau serveurs	Très élevée
AD-01	Authentification / annuaire	Réseau interne	Très élevée
BACKUP-01	Sauvegardes des VM	Réseau sauvegarde	Très élevée

II. Architecture simplifiée

Internet → Pare-feu → WEB-01 (DMZ) → APP-01 → DB-01
Utilisateurs internes → APP-01
AD-01 fournit l'authentification. HYP-01 héberge WEB-01, APP-01, DB-01 et AD-01. BACKUP-01 stocke les sauvegardes.

Informations constatées lors d'un pré-audit
L'hyperviseur n'a pas été patché depuis 6 mois ; un compte administrateur partagé est encore utilisé ; MFA absent sur la console de management ; réseau VM peu segmenté ; snapshots anciens conservés ; sauvegardes montées en permanence ; modèles de VM avec comptes par défaut ; journaux conservés localement ; outils invités de certaines VM non à jour.

III. Méthode de cotation utilisée

Pour ce TD, utilisez une matrice qualitative simplifiée. La note de risque est calculée par :

Risque = Vraisemblance × Impact

Score	Vraisemblance	Impact
1	Rare	Négligeable
2	Peu probable	Faible
3	Possible	Modéré
4	Probable	Élevé
5	Très probable	Critique

Score total	Niveau
1–4	Faible
5–9	Modéré
10–16	Élevé
17–25	Critique

IV. Travail demandé :

Exercice 1 — Identifier et classer les actifs

1) Identifiez au moins 8 actifs à protéger.

2) Classez-les dans les catégories : matériel, logiciel, données, identité, réseau, sauvegarde, administration.

Actif	Catégorie	Propriétaire / responsable	Pourquoi est-il important ?

Exercice 2 — Menaces, vulnérabilités et scénarios

À partir du cas, complétez au moins 6 scénarios. Distinguez bien : menace ≠ vulnérabilité ≠ risque.

Menace	Vulnérabilité exploitée	Scénario de risque	Actif impacté

Menace	Vulnérabilité exploitée	Scénario de risque	Actif impacté

Exercice 3 — Évaluer et prioriser les risques

Évaluez les six scénarios suivants avec la matrice fournie. Justifiez chaque score en une phrase.

Scénarios à coter :

R1 — Compromission de la console d'administration via identifiants partagés
R2 — Exploitation d'une vulnérabilité non corrigée de l'hyperviseur
R3 — Propagation latérale depuis WEB-01 vers APP-01 / DB-01
R4 — Ransomware chiffrant VM et sauvegardes montées
R5 — Exposition de données sensibles contenues dans un snapshot ancien
R6 — Utilisation d'un compte par défaut présent dans un modèle de VM

ID	V (1–5)	I (1–5)	Score	Niveau
R1				
R2				
R3				
R4				
R5				
R6				

Justification : pour chaque risque, expliquez en une phrase pourquoi vous avez choisi la vraisemblance et l'impact.

ID	Justification (1 phrase)
R1	
R2	
R3	
R4	
R5	
R6	

Exercice 4 — Traiter les risques

Pour les 4 risques les plus importants, proposez des mesures concrètes et indiquez le type de traitement : réduire, éviter, transférer ou accepter.

Risque	Mesures proposées	Type de traitement	Priorité

Exercice 5 — Risque résiduel et décision

Choisissez deux risques élevés/critique. Après application de vos mesures, estimez le risque résiduel. Expliquez si l'organisation peut l'accepter ou si une action supplémentaire est nécessaire.

Risque	Risque initial	Mesures	Risque résiduel	Décision argumentée

V. Questions de synthèse

1. Pourquoi l'hyperviseur est-il un actif particulièrement critique ?
2. Pourquoi un snapshot n'est-il pas une sauvegarde ?
3. Quel est le danger d'un réseau virtuel plat dans un environnement multi-VM ?
4. Pourquoi un compte administrateur partagé dégrade-t-il la traçabilité ?
5. Quel contrôle mettriez-vous en œuvre en premier si vous aviez seulement 30 minutes ? Justifiez.

VI. Questions complémentaires

6. Comment le risque évoluerait-il si DB-01 était placée sur un datastore chiffré mais que les clés étaient stockées sur HYP-01 ?
7. Que change l'utilisation d'un cluster de deux hyperviseurs en matière de disponibilité et de surface d'attaque ?
8. Proposez trois événements à centraliser dans un SIEM pour détecter une compromission de l'environnement virtuel.
9. Construisez une règle simple d'acceptation du risque pour AtlasTech.